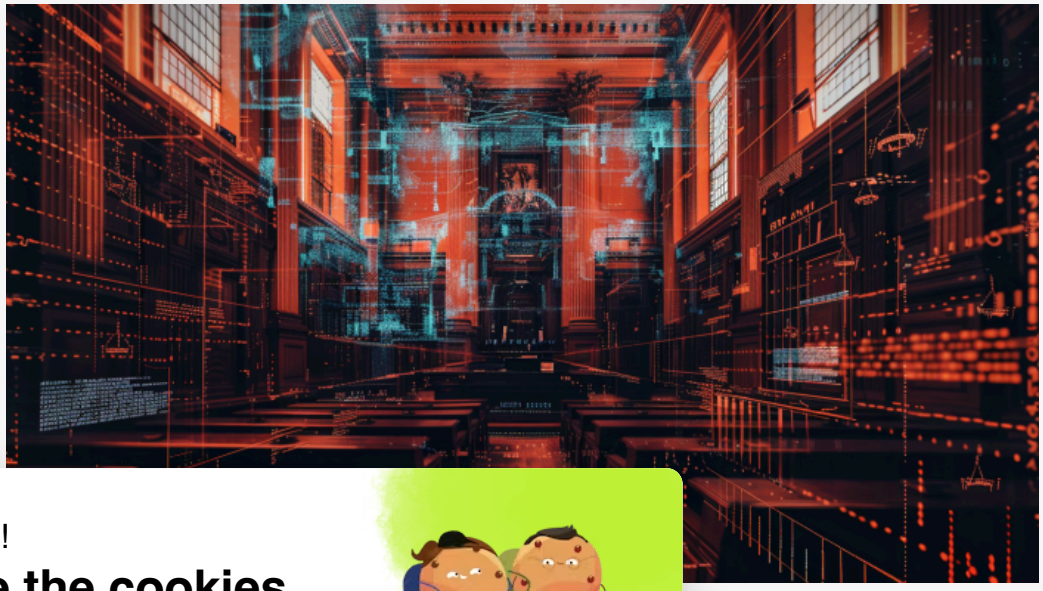
Published on 16 April, 2024 >> 14min

ANALYSIS OF THE APT31 INDICTMENT



Hi there!

We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

Consents certified by axeptio

No, thanks | Let me choose | OK!

Justice (DoJ) released
with APT31, a "hacking
e Security" (MSS)
same day, the
s on several entities
listed in the document.

While the U.S. government doesn't usually disclose investigation methods or IOCs – limiting verifiability of their claims – its attributions have so far never been proven wrong[1]. We gave the indictment a careful read, as such documents always reveal valuable tradecraft information. Key takeaways are:

- APT31 is attributed to the Hubei State Security Department, located in Wuhan;
- Around 2010, APT31 created a front company named "Wuhan XRZ" and used it as a cover for its cyber operations. Another local company, "Wuhan Liuhe" (not accused of being an MSS front), provided support;
- APT31 created and used the RAWDOOR malware, handled a few other malware families used by other Chinese-speaking threat actors, and more recently started using cracked versions of CobaltStrike;
- The group favors a two-band approach to hacking, and goes after subsidiaries, MSPs or spouses of its targets as a means of initial access.

Who is APT31?

APT31, also known as BRONZE VINEWOOD, Zirconium or Judgment
ng threat actor. In the

parliament in 2021;
-0005) captured from

PT31 campaign
ncharacteristic use of
ization infrastructure;
aign against Russian
leveraged Yandex
infrastructure (as
ns in the West).

Hi there!
We're the cookies
We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...
Read our privacy policy Cookie statement
Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing
axeptio

Overall, the group is a skilled threat actor, not known to handle cutting-edge 0-day exploits but still capable of devising creative

homemade tooling.

The private-public ecosystem

As evidenced in our in-depth review of the I-Soon leak, a significant part of the Chinese cyber-offense apparatus is composed of many small to medium companies conducting hacking operations for the benefit of the state. The APT31 indictment features two such companies:

- Wuhan Liuhe Tiangong Science & Technology Co., Ltd ("Wuhan Liuhe"), founded by one of the defendants;
- Wuhan Xiaoruizhi Science & Technology Co., Ltd ("Wuhan XRZ"), a "front" for the Chinese MSS according to the U.S. DoJ.

Among the seven defendants, four are listed as contractors for Wuhan XRZ, one is the founder of Wuhan Liuhe, and the last two do not have an explicit affiliation. Wuhan XRZ is accused of being responsible of the hacking, while Wuhan Liuhe provided support. Beyond them, the indictment mentions "dozens" of MSS intelligence officers, hackers and support staff (identified by the DoJ but not named in the document) who contributed to the

uhe is only considered
sanctioned), since
naintained victim lists,
. In any case, the
ce community
Vuhan XRZ employee
l as a keylogger and
hile "co-located with

Hi there!
We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...
Read our privacy policy Cookie statement
Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing
axeptio

APT31's tactics, techniques and procedures

APT31 appears to have operated using a two-phase methodology, where victims would first receive an email supposedly coming from prominent US journalists. The emails contained legitimate news article excerpts, accompanied by tracking links – which we assume ultimately lead to the original article. Clicking them allowed attackers to obtain preliminary targeting information, such as the type of device on which the email was opened, as well as the public IP address of the recipient. Over 10,000 tracking emails were sent between June and September 2018 only[2].

The threat actor would then use the collected information to engage in direct hacking attempts of the victim's devices based on this information (T1598.003). In particular, the indictment notes that APT31 would **actively target their victims' family members**, so they could go after home routers instead of better protected company networks. The observation that APT31 focused on SOHO devices is consistent with ANSSI's December 2021 report.

Tooling-wise, APT31 initially used a number of malware families (RAWDOOR, Trochilus, EvilOSX, DropDoor/DropCat[3], etc.), all staged through DLL side-loading. Then the attackers switched to cracked versions of CobaltStrike, an infamous commercial penetration-testing tool. In one case, the U.S. DoJ explains the attackers compromised the subsidiary of a victim (a defense for the military) there. The hack exploit (we assume ore exploiting an SQL

loitation (where inimum) for these ictment (for instance, nt activists relied on attachments or links. ng fake Adobe Flash re (T1036).

Hi there!
We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...
Read our privacy policy Cookie statement
Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing
axeptio

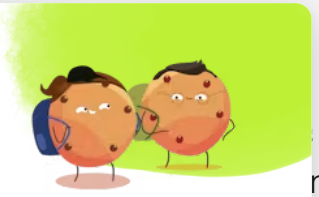
A final, less obvious detail contained in the indictment is the fact that APT31 relied on **double infections** for at least some of the

victims, allowing them to regain access to the network if the first malware implant was discovered.

About the RAWDOOR malware family

In the list of malware families contained in the indictment, we were not immediately able to associate RAWDOOR with a publicly documented malware strain – save for one mention in an archived transcript of a 2016 iSight report. We nonetheless identified a binary sample (SHA256 `c3056e39f894ff73bba528faac04a1fc86deeec57641ad882000d7d40e5874be`) which was first submitted in September 2015 to an online multi-scanner service, identified as "Rawdoor" by some security products, and "Warood" (a close anagram) by others.

A closer inspection of this malware sample turned out that it is a dropper, deploying either an x86 or x64 payload contained in its resources. The second stage is installed as a service, with uncharacteristic stealth compared to Chinese-speaking threat actor techniques documented for that era:


Hi there!
We're the cookies
We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...
Read our privacy policy Cookie statement
Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing
axeptio

- and looks for an
  ng service in
  `vices\`.
- as
  file is timestomped
  `exe` file (T1070.006).
- n automatic startup,
- `-k netsvcs`. The
  key manually to set
  e.
- Finally, the dropper starts the service, causing the second stage to load.

A summary analysis of the next stage by Microsoft can be found here. We would add to it that the sample we studied uses GitHub as a Command & Control channel[4] (`hxxps://raw.githubusercontent[.]com/willbil14/workspaceer/master/9proxy5/ReadMe.txt`). The corresponding GitHub repository (still online at the time of this writing) received 39 commits between August 5, 2015 and June 6, 2017. The Release folder contains additional binaries, such as a copy of RAWDOOR, likely for update purposes; a PlugX sample; penetration testing utilities such as "netcat", and other unidentified malware samples.

Considering that samples of the Warood malware family use "RawDoor" as an internal name and in some logging messages, and that some of them contain traces of being compiled on machines in the Chinese language, we assess with high confidence that this malware family is the one referred to in the indictment. Corresponding indicators of compromise are listed in Appendix.

APT31's flexibility

Hi there!
We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

could change targets
s taking place in the

ween the U.S. and
ariffs on imported
Commerce promised
ering infrastructure
pany, then shortly
Forum. These domains
r malware deployed
mpany.

activists for the Nobel
Norwegian
government as well as a major Norwegian Managed Services Provider (MSP).

- Mid-July 2020, shortly after negative comments from the U.S. administration about China's territorial claims in the South China Sea, APT31 initiated a spearphishing campaign targeting the U.S. Navy and organizations or think tanks related to it.

Assessment

This indictment contains information consistent with pre-existing knowledge on both APT31 tradecraft, and the nature of the cooperation between public and private Chinese entities on cyber-offense matters. While the U.S. opted not to indict members of the MSS (or if it did, chose not to identify them as such), it is obvious from reading the document that it considers private contractors as intelligence community members.

APT31 has targeted (and in many cases, successfully breached) many high-profile entities in the Western world. The indictment provides a comprehensive view of the group's interests, ranging from diplomatic intelligence to the theft of trade secrets and even financial data (see full list in appendix). In addition, the U.S. DoJ indicates that the call data records for "millions of ackers, which hints at mmunications provider

ny more campaigns y this indictment –

Hi there!
We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

The following list contains verticals and (where applicable) entities referred to in the indictment. The organizations

mentioned were targeted by APT31, but it is not possible to determine which of them were successfully breached from the DoJ's information.

Government	White House
	Department of Justice (including spouses of high-ranking officials)
	Department of Commerce
	Department of Labor
	Department of Transportation
	Department of Treasury
	Department of State
	oth parties
	s
	gn staff members
	st Asian country
	Retired national security official

Hi there!
We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...
Read our privacy policy Cookie statement
Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing
axeptio

	43 UK parliament members
Defense	U.S. Naval Academy
	U.S. Naval War College's China Maritime Studies
	Contractor designing flight simulators for the U.S. Navy and U.S. Air Force
Industry	American Steel Company
	Various companies in the aerospace sector
Finance & Law	Multiple global law firms throughout the United States
	Unspecified finance, management consulting and financial rating companies
	ers
	uipment and a 5G ny
	ny
	nulti-factor
	An undisclosed editor of law-firm software

Hi there!

We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

	Likely one or more ISPs, based on the acquisition of call data records
Research	Laboratory specialized in machine learning
	Various research hospitals and institutes
Civil Society	Various journalists, academics and policy experts
	Democracy activists (in the U.S., Hong Kong)
	Uyghur minority
	Unspecified non-profit organization in Washington
	Interparliamentary Alliance on China

Hi there!
We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

ocs)

ities are, at best, a few
vided for their
vailable on our GitHub

```
cbdadd80c717e415ac
c78f46ed9401dea799
28b84df9ca73a3bc1e
7fda8879c55398434ab0f423b0f1c75658bddd925d90437ad2e
76124bdee942090ec4b5f2a7e08ffe6dae758bc747d6565f6c5
c444a2b741273b5bb86c5197d931cbd3b121043e6e6cb5604b0
```

```
f332a941d786148a35cec683edb965ea4bbd6ff6bd871880f30
78a20e644f593acb71d94be96ed1e3a9ba7515be2c50aef8442
e98d8ae395ec7d2bbc29c21fa2bf79e26ada9d8bd5098487027
e89079508dca536019535bb021ae388a990d9cb64e1e6bd769e
fade96ec359474962f2167744ca8c55ab4e6d0700faa142b3d9
bd3be94afa57936741a5debde1eff537dcd7c7bc79ccfa9739c
74f7a3b2a5df81eb7b5e0c5c4af8548e61dc37c608dda458b75
697db25145c2d37f0a521b3ca6b49f1f4d7c3e0c2e57804f531
fefa00b0d9a411029f51f34bfa4ed2327559edfcd4fad5cfc12
c3056e39f894ff73bba528faac04a1fc86deeec57641ad88200
```

Copy

URLs:

```
hxxps://raw.githubusercontent[.]com/will bi114/works
hxxp://web10111.googlecode.com/svn/10111.txt|RAWDOO
```

Copy

Yara rules

The provided Yara rules require Yara 4.1.0(April 26, 2021)and up.

```
                                                    e RawDoor dropper"
                                                    ba528faac04a1fc86de
                                                    mRoot%\\system32\\s
                                                    osoft .NET Framewo
                                                     ascii
                                                     error:%d\x0D\x0A"
        $msg2 = "RegDeleteValue Wow64 . %d\x0D\x0A"
        $msg3 = "CreateService %s success! but Star
        $msg4 = "OutResFile to %s%s False!" ascii
```


Hi there!

We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

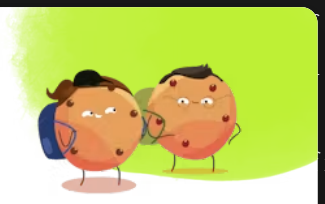
```
        $msg5 = "Can't GetNetSvcs Buffer!" ascii
    condition:
        uint16(0) == 0x5A4D and filesize > 350KB and
        (($service_target and $service_dispname and
}

rule apt31_rawdoor_payload
{
    meta:
        description = "Matches the RawDoor payload"
        references = "TRR240401"
        hash = "fade96ec359474962f2167744ca8c55ab4e6
        date = "2024-04-12"
        author = "HarfangLab"
        context = "file"
    strings:
        $name = "\x0D\x0A================RawDoor %s
        $key = /SOFTWARE\\Clients\\Netra(u|w)/ ascii
        $cmd1 = "Shell " ascii
        $cmd2 = "Selfcmd " ascii
        $cmd3 = "Wsrun " ascii
        $cmd4 = "ping 127.0.0.1 > nul\x0D\x0A"
        $cmd5 = "/c netsh advfirewall firewall add r
        $msg1 = "Allocate pSd memory to failed!" asc
        $msg2 = "Allocate SID or ACL to failed!" asc
                                          ror:%d" ascii
                                          :%u" ascii

                                          filesize < 200KB and
                                          of ($cmd*) and 3 of
```

Copy

Hi there!
We're the cookies



We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio

e DoJ is able to
e of malware,
ous email) to
front company.

breaking in itself and is used by advertisers all over the world in their emailing campaigns. The indictment contains references to a commercial service enabling mass email and mail merge, used to send

those vast quantities of emails to the victims. Previous reporting by ANSSI indicates this is likely GMass. It follows that the information tracking component was not developed by APT31, but is instead a built-in feature of those services.

[3] Likely the malware strain known as DropboxAES.

[4] This behavior is consistent with APT31's use of public or cloud services for similar purposes. The earliest Rawdoor sample we studied (SHA256 `76124bdee942090ec4b5f2a7e08ffe6dae758bc747d6565f6c5941ab81d79044`, from April 2013) used `googlecode[.]com` for that purpose.

MORE ARTICLES



Hi there!

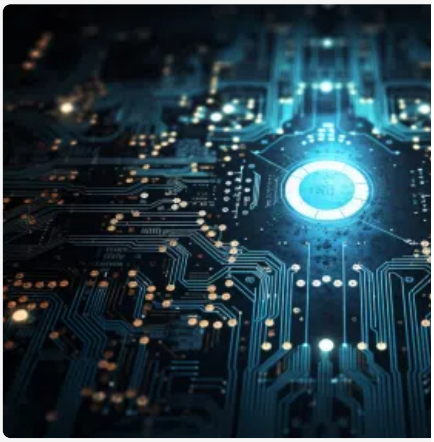
We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio



An introduction to rev engineering .NET AOT applications

About a month ago, we sta reports on activities from D cybercrime outfit reportedl Vietnam. Detonating one o we observed that a new ac being created on the analy followed by...

Mid-year Doppelgänger information operations in Europe and the US

Identifier: TRR240701. Summary This report delves into Doppelgänger information operations conducted by Russian actors, focusing on their activities from early June to late-July 2024. Our investigation was motivated by

READ MORE

CYBER INTELLI



Hi there!

We're the cookies

We waited to make sure that you were interested in the content of this website before bothering you, but we would love to be your companions during your visit...

Read our privacy policy Cookie statement

Here's why we use cookies.
- Data Sharing with Google
- Audience measurement and marketing

axeptio